ID: SECURITY-POL00029-STN00022
Driver: Anastasia Conti
Classification: Internal
Version: 11.0

Secure Product Lifecycle Standard

Contents

1. Overview
2. Scope
3. Statement
   - 3.1. Governance
   - 3.2. Product Backlog
   - 3.3. Development and Code Creation
   - 3.4. Web Crawling
   - 3.5. Delivery
   - 3.6. Storage
   - 3.7. Packaging
   - 3.8. Educational Code
   - 3.9. Security Testing
   - 3.10. End-of-Life Adobe Products or Services
   - 3.11. Use of Third-Party Code and Components
   - 3.12. Data Management
   - 3.13. Vendors
   - 3.14. Operational Security
   - 3.15. Incident Response
   - 3.16. Application Logging
4. Definitions
5. Responsibilities
6. Governing Policy
7. References
8. Document Properties
9. Document History

1. Overview

Adobe is committed to providing secure products and services within our enterprise, and to our customers. To this end, Adobe's Secure Product Lifecycle (SPLC) must meet the standard of due care that is reasonably expected by customers, shareholders, partners, Adobe workers, and the business itself within the Product lifecycle. This Standard outlines the minimum requirements for Adobe's SPLC.

2. Scope

Except as otherwise noted, this Standard applies to all Adobe products and all workers

3. Statement

3.1. Governance

3.1.1 Product teams are required to complete a threat model for all significant changes using the process outlined on the Threat Modeling home page.

3.1.2 Product teams are required to submit new vendor integration requests through Adobe's Vendor Management System. During that process, a security hardening guideline from the vendor is required to be submitted to vsr@adobe.com. For any significant changes to the vendor hardening guideline or architecture after vendor installation, the hardening guideline must be resubmitted to vsr@adobe.com.

3.2. Product Backlog

3.2.1 Product teams are required to maintain a risk-prioritized security backlog in JIRA. It is the responsibility of the Product Team to ensure their backlog debt is remediated as outlined in this Standard, and that a Security Partner is appointed to help with this effort.

3.2.2 Security work items in JIRA map to an SPLC risk priority as follows R0 (blocker), R1 (critical), R2 (major), R3 (normal), R4 (minor), R5 (trivial).

3.2.3 The Product Security backlog will document and comprise of:

3.2.3.1 **Vulnerabilities** (see definition below): These must be scored in accordance with the Severity Level Scoring model outlined in the Vulnerability Management Standard and needs to be remediated within the timelines outlined in the standard.

3.2.3.2 **Non-vulnerabilities** (see definition below): These must adhere to Vulnerability Management Standard remediation timelines as a guideline; however, timelines may be adjusted where agreement between security and the product team has determined a reasonable date.

3.3. Development and Code Creation

3.3.1 Execution of static code analysis and binary analysis tools is required for all significant changes via Kodiak.

3.3.2 The approved automated process to build and distribute code must be used by Product Teams. (see Source Code Security Standard)

3.3.3 Information systems used to create or modify code need to comply with the Laptop/Desktop Configuration Standard and other applicable security standards for the development environment.

3.3.4 Code creation must be performed on secure Adobe networks and never on a third-party network unless VPN is being utilized and is in adherence with the Remote Access Standard.

3.4. Web Crawling

3.4.1 Web pages must have proper authentication and authorization controls in place to protect unauthorized users from accessing the page.

3.5. Delivery

3.5.1 Code delivered externally must be cryptographically signed.

3.5.2 When a manual process to build and distribute code is required, the following practices must be in place:

- Product teams must maintain and retain a log of code sent to customers.
- Transmission channels must be encrypted per the requirements outlined in the Cryptography Standard.

3.6. Storage

3.6.1 Proprietary code must be stored in an approved Adobe code repository. See Source Code Security Standard for approved repositories.

3.6.2 Code repositories must be implemented in accordance with the Source Code Security Standard.

3.7. Packaging

3.7.1 Code requiring packaging must be built using an approved build server, including approved build applications.

3.7.2 Build servers must interface with the code repositories in an automated and secure fashion in order to pull in trusted source code for packaging.

3.7.3 Build servers must comply with applicable Security Policies and Standards as found on Inside Adobe, including access, authorization, and configuration Standards.

3.8. Educational Code

3.8.1 Code posted to internet forums or other public/semi-public venues must be clearly marked as educational code. Copyright and terms of use need to be explicit, and warnings or disclaimers about the safety of the code need to be apparent.

3.9. Security Testing

3.9.1 Security testing is required for Significant Changes (see definition below) and must include, at a minimum, verification that the Open Web Application Security Project (OWASP) top ten are not present prior to release into production for both Adobe enterprise and customer-facing products.

3.9.2 Manual security testing must be performed for significant changes to ensure detection and prevention of common security issues. Dynamic security testing must also be performed for significant changes whenever they are available.

3.10. End-of-Life Adobe Products or Services

3.10.1 Products or services, both Adobe enterprise and customer-facing, which are no longer supported but are still being used by or sold to customers, must have a decommission plan and decommission date that are documented and communicated to the customer.

3.10.2 It is the responsibility of the Product Team to document the decommission plan and decommission date, and to communicate them to the customer.

3.10.3 Security patches must continue to be published, in accordance with vulnerability management severity scores and timelines dictated in the Vulnerability Management Standard, until the decommission date. Non-adherence to this requirement is unethical and is a violation of Adobe's Code of Business Conduct; it may result in disciplinary action (see Violations section below).

3.11. Use of Third-Party Code and Components

3.11.1 Significant product vulnerabilities identified in third-party components must be remediated prior to release.

3.12. Data Management

3.12.1 Products teams must complete a data classification exercise for their environments.

3.12.2 It is the responsibility of the Product Team to ensure they are complying with the Data Classification and Handling Standard.

3.13. Vendors

3.13.1 Products that interact with external vendor systems must also follow the Vendor Information Security Standard. These products will not be approved for release without a completed Vendor Security Review (VSR). For all new vendor integrations, product teams should email a security hardening guideline from the vendor to vsr@adobe.com.

3.13.2 Commercial Off-The-Shelf (COTS) products used within Adobe must also apply and maintain the vendor's security best practices in addition to meeting Adobe's security requirements.

3.14. Operational Security

3.14.1 Products that require operational support, such as those deployed to public clouds, must meet the secure operational requirements identified in Uniform Cloud Security Standard.

3.14.2 Products deployed within Adobe's Enterprise network must:

3.14.2.1 meet the requirements outlined in the Network Security Standard.

3.14.2.2 only use approved Mail Relay Services.

3.14.3 Products using containers must meet the requirements identified in the Container and Orchestration Standard.

3.15. Incident Response

3.15.1 Product Teams must comply with the Information Security Incident Response Standard.

3.16. Application Logging

3.16.1 Critical application processes and events must be logged to comply with the Infrastructure Logging Standard.

4. Definitions

Term	Definitions
COTS	Commercial Off-The-Shelf.
Educational Code	Code intended to teach a principle or show a feature by example but not intended to be used in production environments.
High Risk Product	A high-risk product is: • Any product or service used by customers, employees, or internal systems that store, transmit, modify, or remove Confidential or Restricted data. • Any service that, if destroyed or severely damaged, would cause significant hardship to Adobe's business or customer environments, or otherwise deny access considered to be critical by the Security Team.
Kodiak	Adobe's code analysis platform
Personal Information (PI)	See Data Classification and Handling Standard
Product	A product is something that is built, operated, and maintained by Adobe. Product security includes ensuring security is met during all the critical stages of the product's lifecycle: • Product development • Product testing • Product operations • Product incident response
Secure Product Lifecycle	A set of security activities spanning software development practices, processes, and tools.

Term	Definitions
Service Lifecycle (SLC)	Framework for managing the maturity of development for a project portfolio.
Significant Change(s)	Changes including modification/addition of code, modification/addition of a functionality, product release, system newly determined to contain Restricted or Confidential data.
SPLC Stakeholders	Security-focused teams and employees including, but not limited to: IT Security teams, Digital Media Security Leaders, Digital Marketing Governance, Privacy and Security Architecture Team, Digital Marketing Information Security Team, Cloud Operations Security Team, Document Cloud Security Team, Tech GRC, Risk Advisory & Assurance Services, and Legal.
Upstream Software Source	The originating source of the raw source code that is to be packaged as a deliverable.
Vulnerability	Security vulnerability is a weakness in software or system that could allow an attacker to compromise the integrity, availability, or confidentiality of that software or system.

5. Responsibilities

Group	Responsibilities
Adobe Personnel	• Read, understand, and comply with the requirements in this Standard.
Security	• Review and update this Standard as needed, with assistance from SPLC Stakeholders. • Assist and guide Adobe personnel in complying with this Standard.
Executive Management	• Review and approve this Standard as needed.
SPLC Stakeholders	• Provide input, review, and approve SPLC Standard. • Ensure that respective team-specific Procedures adhere to the SPLC Standard. • Maintain alignment between the SPLC Standard and Adobe's Common Controls Framework.
Product Teams	• Responsible for adhering to this Standard

6. Governing Policy

Adherence to the governing Policy referenced below is required to be compliant with this Standard:

- Information Security Policy

7. References

All Information Systems and Security Policies and Standards links can be found here:

- Container and Orchestration
- Cryptography Standard
- Data Classification and Handling Standard
- Information Security Incident Response Standard
- Infrastructure Logging Standard
- Laptop/Desktop Configuration Standard
- Network Security Standard

- Product Lifecycle Standard
- Remote Access Standard
- Source Code Security Standard
- Uniform Cloud Security Standard
- Vendor Information Security Standard
- Vulnerability Management Standard

8. Document Properties

Coordinator	Ensures Review, Approval and Publication; Facilitates Discussions	Anastasia Conti (Manager, Governance, TechGRC)
Driver	Subject Matter Expert; Owner of Content; Works with Contributors	Anastasia Conti (Manager, Governance, TechGRC)
Approver	Approves Document; Ultimately Responsible for Execution	Jeff Sass (Director, Product Security Engineering)

9. Document History

Version	Approval Date	Changes	Approved By
10.0	July 2024	No Major Changes Minor Changes • Section 3.2 - Removed pointer about backlog items being assigned an SPLC Risk Priority number • Section 3.3.1 – Removed part about conducting manual code review for applications not onboarded to Kodiak • Section 3.15.1 – Updated 'Computer Security Incident Response Standard' to 'Information Security Incident Response Standard' • Section 8 & 9 – Added descriptions for all referenced standards and policies • Approver – Jeff Sass replaced Sangeeta Arora	Jeff Sass, Director, Application Security
11.0	September 2025	Major Changes • Sections related to Exceptions and Violations were removed Minor Changes • Section 3.1.2 – Replaced 'graphiteConnect' with 'Adobe's Vendor Management System' • Section 3.2.1 – 'Security Champion' replaced with 'Security Partner' • Section 3.3.3 – Added the link to the Laptop/Desktop Configuration Standard • Section 7 – Added all the referenced documents within the Standard • Vik Malhotra replaced by Anastasia Conti as the driver of the Standard	Jeff Sass, Director, Product Security Engineering

Signature: Jeff Sass

Email: jsass@adobe.com